

Website Vulnerability Scanner Report

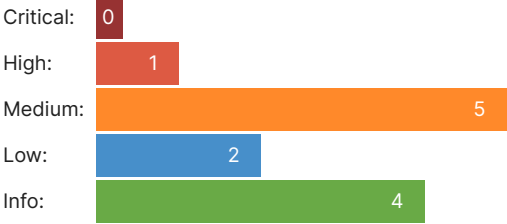
✓ <http://brins.co.id>

Summary

Overall risk level:

High

Risk ratings:



Scan information:

Start time: Apr 06, 2026 / 10:22:01 UTC+07
Finish time: Apr 06, 2026 / 10:28:43 UTC+07
Scan duration: 06 min, 42 sec
Tests performed: 77
Scan status: Finished

Findings

 Vulnerabilities found for angular 15.2.9
port 80/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2026-41423	8.7	0.00038	0.11691	Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to versions 19.2.21, 20.3.19, 21.2.9, and 22.0.0-next.8, a Server-Side Request Forgery (SSRF) vulnerability exists in @angular/platform-server due to improper handling of URLs during Server-Side Rendering (SSR). When an attacker sends a request such as GET /\evil.com/ HTTP/1.1 the server engine (Express, etc.) passes the URL string to Angular's rendering functions. Because the URL parser normalizes the backslash to a forward slash for HTTP/HTTPS schemes, the internal state of the application is hijacked to believe the current origin is evil.com. This misinterpretation tricks the application into treating the attacker's domain as the local origin. Consequently, any relative HttpClient requests or PlatformLocation.hostname references are redirected to the attacker controlled server, potentially exposing internal APIs or metadata services. This issue has been patched in versions 19.2.21, 20.3.19, 21.2.9, and 22.0.0-next.8.
CVE-2026-22610	8.5	0.0002	0.05682	Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to versions 19.2.18, 20.3.16, 21.0.7, and 21.1.0-rc.0, a cross-site scripting (XSS) vulnerability has been identified in the Angular Template Compiler. The vulnerability exists because Angular's internal sanitization schema fails to recognize the href and xlink:href attributes of SVG <script> elements as a Resource URL context. This issue has been patched in versions 19.2.18, 20.3.16, 21.0.7, and 21.1.0-rc.0.

CVE-2025-66412	8.5	0.00023	0.06951	Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Prior to 21.0.2, 20.3.15, and 19.2.17, A Stored Cross-Site Scripting (XSS) vulnerability has been identified in the Angular Template Compiler. It occurs because the compiler's internal security schema is incomplete, allowing attackers to bypass Angular's built-in security sanitization. Specifically, the schema fails to classify certain URL-holding attributes (e.g., those that could contain javascript: URLs) as requiring strict URL security, enabling the injection of malicious scripts. This vulnerability is fixed in 21.0.2, 20.3.15, and 19.2.17.
CVE-2026-27970	7.6	0.00055	0.17457	Angular is a development platform for building mobile and desktop web applications using TypeScript/JavaScript and other languages. Versions prior to 21.2.0, 21.1.16, 20.3.17, and 19.2.19 have a cross-Site scripting vulnerability in the Angular internationalization (i18n) pipeline. In ICU messages (International Components for Unicode), HTML from translated content was not properly sanitized and could execute arbitrary JavaScript. Angular i18n typically involves three steps, extracting all messages from an application in the source language, sending the messages to be translated, and then merging their translations back into the final source code. Translations are frequently handled by contracts with specific partner companies, and involve sending the source messages to a separate contractor before receiving final translations for display to the end user. If the returned translations have malicious content, it could be rendered into the application and execute arbitrary JavaScript. When successfully exploited, this vulnerability allows for execution of attacker controlled JavaScript in the application origin. Depending on the nature of the application being exploited this could lead to credential exfiltration and/or page vandalism. Several preconditions apply to the attack. The attacker must compromise the translation file (xliff, xtb, etc.). Unlike most XSS vulnerabilities, this issue is not exploitable by arbitrary users. An attacker must first compromise an application's translation file before they can escalate privileges into the Angular application client. The victim application must use Angular i18n, use one or more ICU messages, render an ICU message, and not defend against XSS via a safe content security policy. Versions 21.2.0, 21.1.6, 20.3.17, and 19.2.19 patch the issue. Until the patch is applied, developers should consider reviewing and verifying translated content received from untrusted third parties before incorporating it in an Angular application, enabling strict CSP controls to block unauthorized JavaScript from executing on the page, and enabling Trusted Types to enforce proper HTML sanitization.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.00055

EPSS percentile : 0.17457

CISA KEV: False

CVE : [CVE-2026-41423](#), [CVE-2026-22610](#), [CVE-2025-66412](#), [CVE-2026-27970](#)

CVSS V3 : 8.7

CWE : [CWE-1035](#)

Insecure cookie setting: missing HttpOnly flag

CONFIRMED

port 80/tcp

URL	Cookie Name	Evidence
http://brins.co.id/	domain, TSa5bb68c2027, TS01d9e5a3, incap_ses_611_3323467	The server responded with Set-Cookie header(s) that does not specify the HttpOnly flag: Set-Cookie: domain=.brins.co.id Set-Cookie: TSa5bb68c2027=08da83dfadab2000926104a64fa30064aa1f827b715ae0484be911efb96832f19da1ad2d2b694ef00853bf8ea9113000f83e03224256c4fa7dd7c6870cfad584db0c70801df2c21c51739cf133fba67c0040b133e73f251c956222ec9bd33993 Set-Cookie: TS01d9e5a3=01e6a1e6a7805ec10ed1e829c08a8cf6b36e5ba18b7bd63228d471cc26cfff2221e351ea844389453bb40ed230cf9c83251023596b74238b041ece8b6362b3825ff86db0bfce7473f23077109f0624a4b79c69ca90 Set-Cookie: incap_ses_611_3323467=4GMdGt199VUQWxXsVbV6CFpVHmoAAAAGyLhYV+zdQHFHX11cmr2qg== Request / Response

▼ Details

Risk description:

The risk is that an attacker who injects malicious JavaScript code on the page (e.g. by using an XSS attack) can access the cookie and can send it to another site. In case of a session cookie, this could lead to session hijacking.

Recommendation:

Ensure that the HttpOnly flag is set for all cookies.

References:

<https://owasp.org/www-community/HttpOnly>

Classification:

CWE : [CWE-1004](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Insecure cookie setting: domain too loose

CONFIRMED

port 80/tcp

URL	Cookie Name	Evidence
http://brins.co.id/	TS01d9e5a3	Set-Cookie: .brins.co.id Request / Response

▼ Details

Risk description:

The risk is that a cookie set for example.com may be sent along with the requests sent to dev.example.com, calendar.example.com, hostedsite.example.com. Potentially risky websites under your main domain may access those cookies and use the victim session from the main site.

Recommendation:

The **Domain** attribute should be set to the origin host to limit the scope to that particular server. For example if the application resides on server app.mysite.com, then it should be set to **Domain=app.mysite.com**

Classification:

CWE : [CWE-614](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Insecure cookie setting: missing Secure flag**CONFIRMED**

port 80/tcp

URL	Cookie Name	Evidence
http://brins.co.id/	domain, TSa5bb68c2027, TS01d9e5a3	Set-Cookie: domain=.brins.co.id Set-Cookie: TSa5bb68c2027=08da83dfadab2000926104a64fa30064aa1f827b715ae0484be911efb96832f19da1ad2d2b694ef00853bf8ea9113000f83e03224256c4fa7dd7c6870cfad584db0c70801df2c21c51739cf133fba67c0040b133e73f251c956222ec9bd33993 Set-Cookie: TS01d9e5a3=01e6a1e6a7805ec10ed1e829c08a8cf6b36e5ba18b7bd63228d471cc26cff2221e351ea844389453bb40ed230cf9c83251023596b74238b041ece8b6362b3825ff86db0bfce7473f23077109f0624a4b79c69ca90 Request / Response

▼ Details**Risk description:**

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : [CWE-614](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

 Communication is not secure**CONFIRMED**

port 80/tcp

URL	Response URL	Evidence
http://brins.co.id/	http://brins.co.id/	Communication is made over unsecure, unencrypted HTTP.

Risk description:

The risk is that an attacker who manages to intercept the communication at the network level can read and modify the data transmitted (including passwords, secret tokens, credit card information and other sensitive data).

Recommendation:

We recommend you to reconfigure the web server to use HTTPS - which encrypts the communication between the web browser and the server.

Classification:

CWE : [CWE-319](#)

OWASP Top 10 - 2017 : [A3 - Sensitive Data Exposure](#)

OWASP Top 10 - 2021 : [A4 - Insecure Design](#)

OWASP Top 10 - 2025 : [A04 - Cryptographic Failures](#)

 Vulnerabilities found for ckeditor 4.18.0

port 80/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2023-28439	4.7	0.0054	0.6791	cross-site scripting vulnerability has been discovered affecting Iframe Dialog and Media Embed packages. The vulnerability may trigger a JavaScript code. More details at: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2023-28439 https://github.com/ckeditor/ckeditor4/security/advisories/GHSA-vh5c-xwqv-cv9g Affected file: https://cdn.ckeditor.com/4.18.0/full-all/ckeditor.js

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.0054

EPSS percentile : 0.6791

CISA KEV: False

CVE : [CVE-2023-28439](#)

CVSS V3 : 4.7

CWE : [CWE-1035](#)

 Unsafe security header: Content-Security-Policy

port 80/tcp

CONFIRMED

URL	Evidence
-----	----------

http://brins.co.id/	Response headers include the HTTP Content-Security-Policy security header with the following security issues: <pre> frame-ancestors: This directive tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. The recommended value is 'none' or 'self'. script-src: 'unsafe-eval' allows the execution of code injected into DOM APIs such as eval(). script-src: 'self' can be problematic if you host JSONP, Angular or user uploaded files. script-src: 'unsafe-inline' allows the execution of unsafe in-page scripts and event handlers. object-src: We recommend restricting object-src to 'none'. script-src: https: URI in script-src allows the execution of unsafe scripts. script-src: data: URI in script-src allows the execution of unsafe scripts. </pre> Request / Response
---	--

▼ Details

Risk description:

For example, if the unsafe-inline directive is present in the CSP header, the execution of inline scripts and event handlers is allowed. This can be exploited by an attacker to execute arbitrary JavaScript code in the context of the vulnerable application.

Recommendation:

Remove the unsafe values from the directives, adopt nonces or hashes for safer inclusion of inline scripts if they are needed, and explicitly define the sources from which scripts, styles, images or other resources can be loaded.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)



Server software and technology found

port 80/tcp

UNCONFIRMED



Software / Version	Category
 Angular 15.2.9	JavaScript frameworks
 Amazon Web Services	PaaS
 CKEditor	Rich text editors
 dc.js	JavaScript graphics, JavaScript libraries
 Google Font API	Font scripts
 Zone.js	JavaScript frameworks
 Google Analytics GA4	Analytics
 lit-element 4.2.2	JavaScript libraries
 Google Maps	Maps

 MySQL	Databases
 Open Graph	Miscellaneous
 PHP	Programming languages
 DoubleClick Floodlight	Advertising
 PWA	Miscellaneous
 WordPress	CMS, Blogs
 Format	CMS
 Google Tag Manager	Tag managers
 Imperva	Security, CDN
 HSTS	Security
 TypeScript	Programming languages

▼ Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

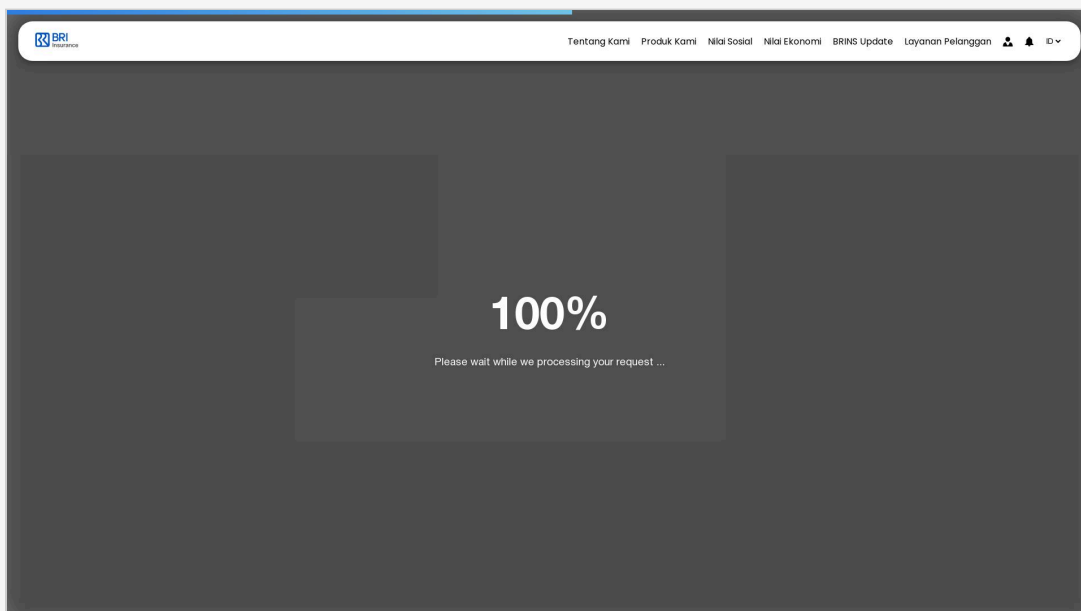
CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Screenshot:



Email Address Exposure

port 80/tcp

UNCONFIRMED



URL	Method	Parameters	Evidence
http://brins.co.id/	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Email Address: digital@work.brins.co.i d Request / Response

▼ Details

Risk description:

The risk is that exposed email addresses within the application could be accessed by unauthorized parties. This could lead to privacy violations, spam, phishing attacks, or other forms of misuse.

Recommendation:

Compartmentalize the application to have 'safe' areas where trust boundaries can be unambiguously drawn. Do not allow email addresses to go outside of the trust boundary, and always be careful when interfacing with a compartment outside of the safe area.

References:

https://owasp.org/Top10/A04_2021-Insecure_Design/

Classification:

CISA KEV: False

CVE : -1

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : A6: Security Misconfiguration

OWASP Top 10 - 2021 : A4: Insecure Design

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Spider Results

UNCONFIRMED



URL	Method	Page Title	Page Size	Status Code
http://brins.co.id/	GET	BRINS BRI INSURANCE	34.66 KB	200
https://login.microsoftonline.com:443/brins.co.id/v2.0/.well-known/openid-configuration	GET		2.08 KB	200

▼ Details

Risk description:

The table contains all the unique pages the scanner found. The duplicated URLs are not available here as scanning those is considered unnecessary.

Recommendation:

We recommend to advanced users to make sure the scan properly detected most of the URLs in the application.

References:

All the URLs the scanner found, including duplicates (available for 90 days after the scan date)



Interesting files found

UNCONFIRMED



port 80/tcp

URL	Page Title	Page Size	Summary
https://login.microsoftonline.com:443/brins.co.id/v2.0/.well-known/openid-configuration		3.52 KB	Microsoft Azure Domain Tenant ID was detected.

▼ Details

Risk description:

The risk is that these files/folders usually contain sensitive information which may help attackers to mount further attacks against the server. Manual validation is required.

Recommendation:

We recommend you to analyze if the mentioned files/folders contain any sensitive information and restrict their access according to the business purposes of the application.

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)



API endpoints

UNCONFIRMED



port 80/tcp

URL	Method	Parameters	Evidence
https://login.microsoftonline.com:443/brins.co.id/v2.0/.well-known/openid-configuration	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Possible API endpoint found at /brins.co.id/v2.0/.well-known/openid-configuration Request / Response

▼ Details

Risk description:

These endpoints may represent an attack surface for malicious actors interested in API-specific vulnerabilities.

Recommendation:

Use the API Scanner to perform a more thorough vulnerability check for these endpoints, if an API specification is present.

Classification:

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Scan coverage information

List of tests performed (77)

Port 80

- ✔ Scanned for version-based vulnerabilities of server-side software
- ✔ Scanned for secure communication
- ✔ Scanned for domain too loose set for cookies
- ✔ Scanned for HttpOnly flag of cookie
- ✔ Scanned for Secure flag of cookie
- ✔ Scanned for version-based vulnerabilities of server-side software
- ✔ Scanned for website technologies
- ✔ Scanned for unsafe HTTP header Content Security Policy
- ✔ Scanned for API endpoints
- ✔ Scanned for emails
- ✔ Scanned for interesting files
- ✔ Performed web-crawling on target
- ✔ Performed Flowmapping
- ✔ Scanned for client access policies
- ✔ Scanned for robots.txt file
- ✔ Scanned for absence of the security.txt file
- ✔ Scanned for CORS misconfiguration
- ✔ Scanned for use of untrusted certificates
- ✔ Scanned for enabled HTTP debug methods
- ✔ Scanned for administration consoles
- ✔ Scanned for information disclosure
- ✔ Scanned for software identification
- ✔ Scanned for sensitive files
- ✔ Performed URL search in Wayback Machine
- ✔ Scanned for enabled HTTP OPTIONS method
- ✔ Scanned for GraphQL endpoints
- ✔ Performed fuzzing for OpenAPI files
- ✔ Scanned for misconfigurations
- ✔ Scanned for directory listing
- ✔ Scanned for passwords submitted unencrypted
- ✔ Scanned for Cross-Site Scripting
- ✔ Scanned for SQL Injection
- ✔ Scanned for Local File Inclusion
- ✔ Scanned for OS Command Injection
- ✔ Scanned for error messages
- ✔ Scanned for debug messages
- ✔ Scanned for code comments
- ✔ Scanned for missing HTTP header - Strict-Transport-Security
- ✔ Scanned for missing HTTP header - Content Security Policy
- ✔ Scanned for missing HTTP header - X-Content-Type-Options
- ✔ Scanned for missing HTTP header - Referrer
- ✔ Scanned for XML External Entity Injection

- ✓ Scanned for Insecure Direct Object Reference
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for internal error code
- ✓ Scanned for login interfaces
- ✓ Scanned for secure password submission
- ✓ Scanned for sensitive data
- ✓ Scanned for Server Side Request Forgery
- ✓ Scanned for Open Redirect
- ✓ Scanned for PHP Code Injection
- ✓ Scanned for JavaScript Code Injection
- ✓ Scanned for Ruby Code Injection
- ✓ Scanned for Python Code Injection
- ✓ Scanned for Perl Code Injection
- ✓ Scanned for Remote Code Execution through Log4j
- ✓ Scanned for Server Side Template Injection
- ✓ Scanned for Remote Code Execution through VIEWSTATE
- ✓ Scanned for Prototype Pollution
- ✓ Scanned for Exposed Backup Files
- ✓ Scanned for Request URL Override
- ✓ Scanned for HTTP/1.1 Request Smuggling
- ✓ Scanned for CSRF
- ✓ Scanned for NoSQL Injection
- ✓ Scanned for Insecure Deserialization
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure
- ✓ Scanned for Session Token in URL
- ✓ Scanned for Response Header Injection
- ✓ Scanned for missing HTTP header - Rate Limit
- ✓ Scanned for PEM-encoded private key material
- ✓ Scanned for partial PEM-encoded private key material

Scan parameters

Target:	http://brins.co.id
Scan type:	Deep
Authentication:	False
fingerprint:	True
software_vulnerabilities:	True
check_robots:	True
outdated_js:	True
untrusted_certificates:	True
client_access_policies:	True
http_debug_methods:	True
security_txt:	True
cors_misconfiguration:	True
resource_discovery:	True

sensitive_files:	True
admin_consoles:	True
interesting_files:	True
server_info_disc:	True
server_software:	True
misconfigurations:	True
graphql_endpoint:	True
fuzz_openapi_locations:	True
approach:	Auto
depth:	10
max_time:	3600
requests_per_second:	100
xss:	True
sqli:	True
lfi:	True
oscmdi:	True
ssrf:	True
open_redirect:	True
broken_authentication:	True
php_code_injection:	True
js_code_injection:	True
ruby_code_injection:	True
python_code_injection:	True
perl_code_injection:	True
log4j_rce:	True
ssti:	True
xxe:	True
viewstate_rce:	True
prototype_pollution:	True
backup_files:	True
request_url_override:	True
http_request_smuggling:	True
csrf:	True
insecure_deserialization:	True
nosqli:	True
session_fixation:	True
idor:	True
jwt:	True
response_header_injection:	True
security_headers:	True
cookie_security:	True
directory_listing:	True
secure_communication:	True
weak_password_submission:	True
error_debug_messages:	True
password_cleartext:	True
cross_domain_source:	True
mixed_content:	True
sensitive_data:	True
login_interfaces:	True
file_upload:	True
openapi_documents:	True
path_disclosure:	True
sql_statement_in_request:	True
password_in_response:	True
session_token_in_url:	True
api_endpoint:	True

Scan stats

Unique Injection Points Detected:	2
URLs spidered:	2
Total number of HTTP requests:	12736
Average time until a response was received:	18ms
Total number of HTTP request errors:	63
